

GSG-03

Policy Templates

[Acceptable Use](#) · [Password Rules](#) · [Incident Response](#)

Three ready-to-use policy documents written in plain language your team will actually read. Customize the highlighted fields with your business name, have staff sign them, and you are done.

HOW TO USE THESE TEMPLATES

Step 1 — Customize: Replace **[YOUR BUSINESS NAME]** throughout each policy with your business name. Review each section and adjust any details to reflect how your business actually operates.

Step 2 — Review: Share the policies with a trusted advisor or legal counsel before distributing. These templates are a solid starting point but should be validated against your specific situation.

Step 3 — Distribute and collect acknowledgment: Share each policy with all staff. Use the signature section at the end of each policy to record that employees have read and understood it.

Step 4 — Review annually: Set a calendar reminder to review your policies once a year and update them if anything has changed.

POLICY 1 OF 3

Acceptable Use PolicyRules for Using
Business Technology

Business Name	[YOUR BUSINESS NAME]
Version	1.0
Effective Date	[DATE]
Review Date	Annually
Policy Owner	[Owner / Office Manager]

PURPOSE

This policy sets out the rules for using technology at [YOUR BUSINESS NAME] — including computers, laptops, mobile devices, internet access, email, and any software or cloud services used for work. The goal is to make sure business technology is used appropriately, that client and business information stays protected, and that everyone understands what is and is not acceptable.

WHO THIS APPLIES TO

This policy applies to everyone who uses [YOUR BUSINESS NAME] technology — employees, contractors, part-time staff, and anyone else given access to our systems.

USING BUSINESS TECHNOLOGY RESPONSIBLY**Computers, laptops, and mobile devices**

- Business technology is provided for work purposes. Limited personal use is fine, but it should not interfere with your job or use up excessive resources.
- You are responsible for any device assigned to you — at the office and when working elsewhere.
- Lock your screen or log out when you step away from your workstation. Even for a few minutes.
- Do not allow family members or friends to use business devices.

Email and messaging

- Business email is for work. Do not use it to send anything offensive, harassing, or unrelated to your role.
- Be careful with attachments and links — especially in unexpected emails, even from people you know.
- Do not use your work email address to sign up for personal services or accounts.

- Be aware that business email may be reviewed by management in appropriate circumstances.

Internet use

- Internet access is provided for work. Reasonable personal use during breaks is acceptable.
- Do not visit sites or download content that is illegal, offensive, or not work-related during business hours.
- Do not install software on business devices without approval from [Owner / Office Manager].

WHAT IS NOT ALLOWED

- Accessing systems, accounts, or files you are not authorized to use.
- Sharing your login credentials with anyone — including colleagues or IT support.
- Sending client or business data through your personal email or to unauthorized cloud storage.
- Downloading or installing unauthorized software.
- Using business technology for personal business activities or financial gain.
- Posting confidential business or client information on social media or public platforms.

HANDLING CLIENT AND BUSINESS INFORMATION

- Client records, financial data, and confidential business information must only be stored on approved systems.
- Do not send sensitive information through personal email or messaging apps.
- Printed documents containing sensitive information must be secured when not in use and shredded when no longer needed.

REPORTING PROBLEMS

If you receive a suspicious email, notice something unusual on your computer, or accidentally send information to the wrong person — report it to [Owner / Office Manager] right away. Prompt reporting is always the right call, regardless of how the situation arose. There will be no negative consequences for honest, timely reporting.

CONSEQUENCES

Deliberate or repeated violations of this policy may result in disciplinary action, up to and including termination.

EMPLOYEE ACKNOWLEDGMENT

By signing below, I confirm that I have read, understood, and agree to follow the [YOUR BUSINESS NAME] Acceptable Use Policy.

Employee Name (Print)	Signature	Date

Business Name	[YOUR BUSINESS NAME]
Version	1.0
Effective Date	[DATE]
Review Date	Annually
Policy Owner	[Owner / Office Manager]

WHY PASSWORDS MATTER

Stolen or weak passwords are one of the most common ways unauthorized people gain access to business systems. This policy sets out the rules for creating and protecting passwords at [YOUR BUSINESS NAME]. Following these rules significantly reduces the risk of a breach.

PASSWORD REQUIREMENTS

For all accounts

- Passwords must be at least 12 characters long. Longer is better — 16 or more is ideal.
- Passwords must not include your name, your business name, or easily guessable information like a birthday or pet name.
- Never reuse a password from another account — especially between work and personal accounts.
- Passphrases — a sequence of three or more random words — are a great option. They are easy to remember and hard to guess.

For accounts with access to sensitive information

- Passwords must be at least 16 characters.
- Change these passwords immediately if there is any reason to think they may have been compromised.

TWO-STEP VERIFICATION (MULTI-FACTOR AUTHENTICATION)

Two-step verification adds a second layer of protection to your accounts. Even if someone steals your password, they cannot log in without the second step (usually a code sent to your phone). This is required for:

- Business email (Microsoft 365 or Google Workspace)
- Any cloud services used for client work or storing business data
- Remote access or VPN
- Banking and financial platforms

If you receive a two-step verification prompt that you did not initiate, refuse it and report it immediately. This is a sign that someone is trying to access your account.

PASSWORD MANAGER

[YOUR BUSINESS NAME] provides access to a business password manager. All staff are [required / encouraged] to use it for work accounts. The password manager generates and stores strong, unique passwords for every account — so you only need to remember one master password.

WHAT NOT TO DO

- Do not share your password with anyone — not even your manager or IT support.
- Do not write passwords on sticky notes or in unprotected documents.
- Do not use the same password for work and personal accounts.
- Do not send passwords by email, text, or messaging apps.

IF YOU THINK A PASSWORD HAS BEEN COMPROMISED

- Change it immediately.
- Report it to [Owner / Office Manager] right away.
- Check whether any other accounts use the same or a similar password and change those too.

EMPLOYEE ACKNOWLEDGMENT

By signing below, I confirm that I have read, understood, and agree to follow the [YOUR BUSINESS NAME] Password Policy.

Employee Name (Print)	Signature	Date

POLICY 3 OF 3

Incident Response Plan

What to Do When
Something Goes
Wrong

Business Name	[YOUR BUSINESS NAME]
Version	1.0
Effective Date	[DATE]
Last Tested	[DATE OF LAST PRACTICE EXERCISE]
Policy Owner	[Owner / Office Manager]

PURPOSE

This plan tells everyone at [YOUR BUSINESS NAME] what to do if we experience a security incident — such as a cyberattack, a data breach, a ransomware infection, or a situation where client or business information may have been exposed. Having a written plan means we can respond quickly, limit the damage, and recover faster.

Print this plan and keep a copy somewhere accessible. Do not rely on being able to find it on a computer if your systems are compromised.

EMERGENCY CONTACT LIST — PRINT THIS PAGE

Who	Contact
Internal Contact (Owner / Manager)	[Name and mobile number]
IT Provider / Managed Service Provider	[Company, contact name, phone, email]
Cyber Insurance — Claims Hotline	[Insurer name, policy number, claims phone]
Legal Counsel	[Lawyer name and phone]
Canadian Centre for Cyber Security	1-833-CYBER-88 · cyber.gc.ca
RCMP Cybercrime	report.cybercrime.gc.ca

STEP 1 — RECOGNIZE THAT SOMETHING MAY BE WRONG

Common signs of a security incident:

- Files you cannot open, or a message demanding payment to restore access (ransomware).
- Password reset notifications or login alerts you did not trigger.
- Unusual emails sent from your account that you did not write.

- Staff reporting that clients received strange communications from your business.
- Computers running unusually slowly, or programs behaving strangely.
- A colleague receiving a phishing email that got through.

If you notice any of these — or anything else that feels wrong — contact [Owner / Office Manager] immediately. Do not try to fix it yourself.

STEP 2 — STOP AND CONTAIN

- Disconnect the affected computer from the internet by unplugging the network cable or turning off Wi-Fi — **but do not turn the computer off**. Turning it off can destroy evidence needed for investigation.
- Change passwords for any accounts that may have been affected — starting with email.
- Call your IT provider immediately and let them lead the technical response.
- Do not delete any files, emails, or logs related to the incident.
- Write down what happened, what you noticed, and what steps you took — with timestamps.

STEP 3 — NOTIFY THE RIGHT PEOPLE

[YOUR BUSINESS NAME] may be legally required to notify affected clients, regulators, or law enforcement depending on the type of incident. Contact your legal counsel as early as possible.

- **Canada — PIPEDA:** Notify the Office of the Privacy Commissioner if the breach poses a real risk of significant harm to individuals. Visit priv.gc.ca.
- **Quebec — Law 25:** Additional notification requirements may apply. Consult legal counsel.
- **Healthcare:** If protected health information is involved, additional obligations under provincial health privacy legislation may apply.
- **Payment cards:** If payment card data was involved, notify your payment processor immediately.
- **Cyber insurance:** Notify your insurer early — many policies require prompt notification to preserve coverage.

STEP 4 — RECOVER AND GET BACK TO NORMAL

- Only restore systems from backups after your IT provider confirms the threat has been removed.
- Reset passwords on all affected systems — and any other systems that use the same passwords.
- Communicate clearly with your team about what happened and what is being done.

STEP 5 — LEARN FROM IT

Within 30 days of resolving the incident, hold a short review with your team to answer: What happened? How did we detect it? What did we do well? What would we do differently? Update this plan based on what you learned.

ANNUAL PRACTICE EXERCISE

[YOUR BUSINESS NAME] will walk through a practice scenario at least once per year to make sure everyone knows what to do before a real incident occurs.

ABOUT THIS DOCUMENT

Developed with assistance from Claude (Anthropic) and reviewed by Paul Green, CISSP. Validate against your jurisdiction's requirements with legal counsel.